

BÁO CÁO NHÓM VÀ BẢNG ĐÓNG GÓP THÀNH VIÊN - GROUP 5

1. Mô tả phương pháp (Methodology)

Để triển khai hệ thống lưu trữ tương thích S3 an toàn trên môi trường Kubernetes, Nhóm 5 đã áp dụng các phương pháp luận và nguyên tắc thiết kế hạ tầng đám mây sau:

- **Phân tách trách nhiệm (Separation of Concerns):** Toàn bộ hệ thống được module hóa thành 5 giai đoạn độc lập nhưng liên kết chặt chẽ với nhau: Thiết lập rào chắn nền tảng → Triển khai hạ tầng lưu trữ → Kiểm chứng phân quyền bảo mật → Đánh giá hiệu năng và nút thắt cổ chai → Phục hồi sau thảm họa.
- **Nguyên tắc Đặc quyền tối thiểu (Least Privilege):** Hệ thống được kiểm soát ở cả hai cấp độ. Về mặt mạng, NetworkPolicy chỉ cho phép các Pod mang nhãn hợp lệ tiếp cận dịch vụ. Về mặt dữ liệu, quyền truy cập S3 được chia nhỏ thành các vai trò (owner, ingestor, analyst) với bộ quyền Đọc/Ghi/Liệt kê được gán chính xác đến từng bucket riêng biệt.
- **Kiểm soát tài nguyên chặt chẽ (Resource Quota & Guardrails):** Khởi tạo ngân sách tài nguyên cố định ngay từ đầu để ngăn chặn sự cố cạn kiệt tài nguyên (Noisy Neighbor), đảm bảo sự ổn định cho toàn bộ cụm máy chủ chung.
- **Phát triển dựa trên kiểm thử (Test-Driven Validation):** Mọi cấu hình (từ hạn mức CPU đến quyền S3) đều được đối chứng thông qua 22 kịch bản kiểm thử độc lập, đảm bảo hành vi thực tế của hệ thống khớp 100% với thiết kế lý thuyết.

2. Các bước thực hiện (Execution Steps)

Quá trình triển khai được nhóm thực hiện tuần tự qua 5 bước, bám sát vòng đời của một dự án Cloud Native thực tế:

Bước 1: Khởi tạo nền tảng và rào chắn (Nguyễn Xuân Tiến - Vai trò A)

Đây là bước đặt nền móng hạ tầng và bảo mật cho toàn bộ dự án, được thực hiện với độ chính xác cao nhất nhằm đảm bảo an toàn cho cụm GKE:

- **Thiết lập không gian cách ly (Namespace):** Khởi tạo namespace `bd-g05` đóng vai trò là ranh giới logic, cô lập hoàn toàn môi trường làm việc của Nhóm 5 khỏi các nhóm khác trên cùng một cụm Kubernetes.
- **Xây dựng Rào chắn Tài nguyên (ResourceQuota):** Phân tích nhu cầu của hệ thống lưu trữ và thiết kế chính sách `team-budget`. Cấu hình này áp đặt giới hạn cứng để ngăn chặn việc lạm dụng: tối đa 10 Pods, 2 PersistentVolumeClaims (PVCs), tổng dung lượng lưu trữ 8Gi. Giới hạn tính toán được khóa chặt ở mức `requests.cpu: 2, limits.cpu: 4` và bộ nhớ tối đa 4Gi.

- **Kiểm chứng tính toàn vẹn của Guardrails:** Để đảm bảo rào chắn hoạt động, tôi đã chủ động thiết kế 2 kịch bản giả lập. Kịch bản `positive.yaml` (yêu cầu trong hạn mức) được hệ thống cấp phép thành công. Ngược lại, kịch bản `negative.yaml` (có ý yêu cầu 3 CPU) đã bị bộ điều khiển API Server chặn đứng ngay lập tức với mã lỗi `Forbidden (Exceeded Quota)`.
- **Tường lửa nội bộ (NetworkPolicy):** Triển khai chính sách bảo mật mạng `private-object-store` hướng trực tiếp đến ứng dụng lưu trữ. Tường lửa này chặn theo mặc định (`default deny`) mọi luồng truy cập (Ingress) không xác định. Nó chỉ mở cửa cho các Pod nội bộ mang nhãn quyền truy cập hợp lệ (`access: s3`), ngăn chặn tuyệt đối các kỹ thuật dò quét cổng từ các namespace ngoài lai (`outsider namespaces`).

Bước 2: Triển khai dịch vụ lưu trữ (Trần Thuỳ Dương - Vai trò B)

- Vận hành kịch bản Python (`make_identities.py`) để sinh bộ khóa mã hóa và cấu hình phân quyền S3 (`s3.json`), sau đó đưa lên cụm Kubernetes dưới dạng Secret (`s3-config`).
- Khởi tạo PersistentVolumeClaim (PVC) định dạng `ReadWriteOnce` để cấp phát khối lượng lưu trữ vật lý bền vững cho dữ liệu.
- Cấu hình tệp YAML và triển khai Deployment cho máy chủ `SeaweedFS`, ánh xạ cổng 8333 và liên kết PVC để duy trì trạng thái hệ thống.

Bước 3: Xác thực và kiểm chứng bảo mật (Nguyễn Hữu Thành Đạt - Vai trò C)

- Trực tiếp khởi chạy các Pod máy khách (`owner`, `ingestor`, `analyst`, `blocked`) để tiến hành 22 kịch bản kiểm thử bảo mật khắt khe.
- Xác minh tường lửa (N01-N04) và quyền quản trị RBAC (K01-K06).
- Thực thi các tác vụ GET/PUT/LIST (S01-S12) lên dịch vụ S3. Dựa trên kết quả lỗi truy cập, trực tiếp phân tích và điều chỉnh logic tệp `s3.json` để khắc phục triệt để tình trạng cấp quyền sai lệch, đạt chứng nhận 12/12.

Bước 4: Đo lường và đánh giá hiệu năng (Đặng Xuân Đào - Vai trò D)

- **Thực hiện ép tải (Benchmarking):** Chạy kịch bản kiểm thử hiệu năng cho cả hai tác vụ ghi (PUT) và đọc (GET) dữ liệu với 2 mức tải: 1 luồng (`concurrency=1`) và 4 luồng (`concurrency=4`). Mỗi kịch bản lặp lại 3 lần (tổng 6 đợt test) để đảm bảo độ tin cậy của số liệu.
- **Xử lý dữ liệu:** Lọc và trích xuất 12 dòng dữ liệu tóm tắt về tốc độ xử lý (Goodput) và độ trễ (Latency) từ các file log thô xuất ra định dạng CSV.
- **Kiểm tra chéo bảo mật (Security Validation):** Sử dụng các Pod `ingestor` và `analyst` để thực hiện các hành vi sai quyền (`ingestor` thử đọc file, `analyst` thử ghi file). Xác nhận hệ thống đã chặn thành công và trả về mã lỗi 403 `AccessDenied`.

Bước 5: Thử nghiệm phục hồi sau thảm họa (Nguyễn Hữu Cảnh - Vai trò E)

- Lên kịch bản mô phỏng sự cố hệ thống sập cục bộ bằng cách can thiệp xóa thủ công Pod điều khiển lưu trữ.
- Theo dõi và ghi nhận quá trình Kubernetes tự phục hồi Pod mới và gắn (mount) lại thành công dữ liệu từ PVC cũ.
- Đo lường thời gian đáp ứng phục hồi RTO và giải trình các hạn chế của kiến trúc hiện tại so với tiêu chuẩn High Availability (Độ sẵn sàng cao).

3. Bảng đóng góp thành viên

STT	Họ và Tên	Vai trò / Nhiệm vụ đảm nhiệm	Đóng góp
1	Nguyễn Xuân Tiến	Vai trò A: Thiết lập Namespace, Resource-Quota, NetworkPolicy, cấu trúc hạ tầng.	20%
2	Trần Thuỳ Dương	Vai trò B: Cấu hình Secret S3, cấp phát PVC, triển khai SeaweedFS.	20%
3	Nguyễn Hữu Thành Đạt	Vai trò C: Chạy 22 kịch bản test, phân tích lỗi bảo mật, tối ưu hóa JSON policies.	20%
4	Đặng Xuân Đào	Vai trò D: Đo lường hiệu năng, tính toán Goodput, độ trễ và phân tích nghẽn cổ chai.	20%
5	Nguyễn Hữu Cảnh	Vai trò E: Thực thi kịch bản thảm họa, đo lường phục hồi RTO và đánh giá dữ liệu.	20%